

App Consent Grant Investigation Playbook

Microsoft Learn field guide for illicit application consent investigations

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for identifying, scoping, investigating, recovering from, and documenting app consent grant attacks in Microsoft Entra and Microsoft 365 environments.
Primary audience	SecOps analysts, incident responders, identity administrators, application administrators, tenant administrators, and IT operations teams.
Reference source	https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-app-consent
Generated	2026-07-02
Use note	
This document is a condensed field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest workflow images, prerequisites, role requirements, portal paths, and command syntax.	

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Investigation objective and expected outcome

An app consent grant investigation should determine whether an application was granted access to protected resources in a suspicious or illicit way, which users or administrators granted consent, what permissions were granted, whether data or mailboxes were accessed, and what recovery actions are required to reduce further risk.

Outcome statement

At the end of the investigation, the analyst should be able to answer: What application is involved? Who granted consent? Was it user consent or admin consent? What permissions/scopes were granted? Which accounts and resources were exposed? Did the application access data? What permission grants or service principals were removed or remediated?

2. At-a-glance workflow

Step	Phase	Focus
1	Collect initial incident facts	Capture IoCs, date/time noticed, date range, number and names of compromised accounts, roles of impacted accounts, related Enterprise Applications, and user reports of permission prompts.
2	Identify the application and consent grants	Find the app registration, service principal, permission grants, delegated/application permissions, consent type, and grant timestamp where available.
3	Assess permissions and blast radius	Review granted scopes, high-risk permissions, affected users/resources, privileged impact, and whether Exchange, SharePoint, Graph, or other Microsoft 365 data could be accessed.
4	Correlate sign-in and audit evidence	Review Microsoft Entra audit logs, sign-in logs, application activity, user activity, and any related mailbox/file/application telemetry.
5	Contain and recover	Remove suspicious grants, disable or delete malicious service principals/apps when appropriate, revoke sessions, reset affected accounts, and review MFA/security info and mailbox persistence.
6	Document and improve controls	Record evidence, timeline, impact, recovery actions, control gaps, and recommendations for consent governance, app review, and least-privilege permissions.

3. Readiness prerequisites

Consent model knowledge: Review consent permission types and understand the difference between delegated permissions, application permissions, user consent, and admin consent.

Initial case data: Collect IoCs, incident discovery time, investigation date range, compromised account count/names, roles of affected accounts, related Enterprise Applications, and user reports of suspicious permission prompts.

Microsoft Graph PowerShell: Ensure the Microsoft.Graph PowerShell module is installed on the investigation workstation.

Tenant and workstation access: The Microsoft Learn source calls out tenant-level Global Administrator rights for the provided script and local administrator rights on the machine used to run scripts.

Permission export capability: Download and run the referenced AzureADPSPPermissions script where appropriate to export application permission data for review.

Logging and evidence: Ensure Microsoft Entra audit logs, sign-in logs, application activity, mailbox/file activity, and SIEM/Sentinel evidence are available for the incident window.

Microsoft Learn prerequisite highlight

The Microsoft Learn article explicitly lists required customer data, system requirements, installation of the Microsoft.Graph PowerShell module, and use of a permissions export script that writes output to Permissions.csv.

4. Investigation checklist

Initial triage and scope

- ☐ Capture IoCs, incident discovery time, date range, impacted account names, account roles, and related Enterprise Applications.
- ☐ Identify whether users reported an application requesting permissions to data on their behalf.
- ☐ Preserve relevant sign-in, audit, and application evidence for the investigation window.

Application and consent review

- ☐ Identify the application/service principal involved and validate publisher, owners, redirect URIs, credentials, and tenant presence.
- ☐ Determine whether the consent was user consent or admin consent where evidence is available.
- ☐ Review delegated and application permissions and map them to data/resources at risk.
- ☐ Export and review permission grants using Microsoft Graph PowerShell or approved tooling.

User and account impact

- ☐ Identify all users who granted consent or were impacted by application access.
- ☐ Prioritize highly privileged accounts such as Global Administrator and accounts with access to Microsoft Exchange, SharePoint, or other sensitive workloads.
- ☐ Review sign-ins, MFA/security info changes, mailbox rules, forwarding, file access, and other user activity after suspicious consent.

Containment and recovery

- ☐ Revoke suspicious app permissions/grants and remove malicious or unauthorized service principals where appropriate.
- ☐ Disable the application or block access while the investigation continues when risk is confirmed or likely.
- ☐ Revoke user sessions, reset passwords, and require MFA/security info re-registration for impacted users when compromise is suspected.
- ☐ Review tenant consent settings, admin consent workflows, publisher verification, and app governance controls.

Closure and governance improvement

- ☐ Document timeline, evidence, permissions, users/resources affected, and recovery steps completed.
- ☐ Record lessons learned and update consent approval, monitoring, and response procedures.
- ☐ Create follow-up actions for app review, owner assignment, least-privilege permissions, user consent restrictions, and periodic access reviews.

5. Detailed investigation guidance

5.1 Start with incident facts and user reports

- Capture the incident date range, indicators of compromise, related accounts, account roles, and any user reports of application permission prompts.
- Identify all Enterprise Applications that might be related to the incident and preserve evidence before removing grants or deleting objects.
- Determine whether the case started from user reporting, audit detections, application inventory review, or suspicious downstream activity.

5.2 Identify the app, service principal, and permission grants

- Find the application and service principal in the tenant and validate names, IDs, publisher information, owners, credentials, redirect URIs, and app type.
- Review OAuth permission grants, app role assignments, delegated permissions, application permissions, and consent records where available.
- Focus on high-impact permissions and whether the app can access mail, files, directory data, user profiles, or administrative APIs.

5.3 Correlate consent with account and resource activity

- Use Microsoft Entra audit logs and sign-in logs to align consent events, application sign-ins, user activity, and administrator actions.
- For impacted users, review mailbox access, email forwarding, inbox manipulation rules, file access, app activity, and suspicious administrative changes.
- Where available, correlate with Microsoft Defender XDR, Microsoft Defender for Cloud Apps, Microsoft Sentinel, and other SIEM evidence.

5.4 Contain suspicious consent grants

- Remove suspicious OAuth grants or app role assignments after preserving evidence needed for the case.
- Disable, delete, or quarantine the application/service principal if it is confirmed malicious or unauthorized, following tenant policy and change-control requirements.
- Revoke sessions and remediate affected identities when user or administrator compromise is suspected.

5.5 Improve governance after recovery

- Review whether users can consent to applications and whether admin consent workflow should be tightened.
- Assign owners to enterprise applications and regularly review high-privilege permissions.
- Adopt least-privilege permission reviews and create monitoring for risky consent events, newly granted high-impact scopes, and unfamiliar apps.

6. Handy command and query starting points

Reminder

Validate command syntax and permissions against the latest Microsoft Learn docs before running in a customer tenant. Scope permissions and use least privilege.

Use case	Example / location	Why it matters
----------	--------------------	----------------

Install Microsoft Graph PowerShell	Install-Module -Name Microsoft.Graph -Verbose	The Microsoft Learn playbook lists Microsoft.Graph PowerShell as a system requirement.
Connect to Microsoft Graph for permission review	Connect-MgGraph -TenantId "<tenant-id>" -Scopes "Application.Read.All", "User.Read.All"	The article provides this style of connection example before running the permissions export script.
Export application permissions	./Get-AzureADPSPPermissions.ps1 Export-Csv -Path "Permissions.csv" -NoTypeInfo	The article references exporting permissions to a CSV file for review.
Disconnect Microsoft Graph session	Disconnect-MgGraph	Close the investigation session after collecting the required export.
Review consent audit events	AuditLogs where OperationName == "Consent to application"	Useful KQL starting point for finding consent events when audit logs are available. Validate table availability in the customer environment.

7. Evidence matrix

Question	Helpful evidence sources
Which app is involved?	Enterprise Applications, App registrations, service principal ID, app ID, publisher, owners, credentials, redirect URIs
Who granted consent?	Microsoft Entra audit logs, consent records, admin/user consent evidence, account roles
What permissions were granted?	OAuth permission grants, app role assignments, delegated/application permissions, permissions.csv export
What data was exposed?	Permission scope analysis, workload logs, mailbox/file/app telemetry, Graph activity if available
Was the app used after consent?	Service principal sign-ins, application sign-ins, API activity, Defender/Sentinel evidence
Were users compromised?	User sign-ins, MFA/security info changes, mailbox rules/forwarding, file access, role changes
Was risk contained?	Grant revocation evidence, app/service principal disable/delete status, user session revocation, password/MFA remediation

8. Closure notes template

- ☐ Incident summary: suspected illicit app consent grant, detection source, and initial trigger.
- ☐ Timeline: user/admin consent time, application activity, discovery time, containment time, recovery completion.
- ☐ Scope: app/service principal IDs, permissions granted, impacted users, privileged accounts, workloads/resources exposed.
- ☐ Evidence reviewed: Microsoft Entra audit logs, sign-in logs, permission exports, service principal/app sign-ins, mailbox/file/app telemetry.
- ☐ Verdict: malicious, suspicious, benign, or inconclusive with rationale.
- ☐ Actions completed: grants revoked, app disabled/deleted, sessions revoked, passwords reset, MFA/security info reviewed, persistence removed.
- ☐ Follow-up recommendations: restrict user consent, strengthen admin consent workflow, review high-risk permissions, assign app owners, and monitor consent events.

9. Authoritative source

Primary Microsoft Learn article: [App consent grant investigation | Microsoft Learn](#)

This field guide does not replace the official article. Always reference Microsoft Learn for the latest workflow diagrams, role/permission details, portal paths, and command syntax.